

Pongamos a prueba la seguridad de un agente de IA

OWASP Agentic Top 10 (ASI) y OWASP LLM Top 10 aplicados a arquitecturas de agentes en producción.

Alexander Saravia

```
agent_session.log
```

```
$ agent.run(task)
```

```
tools ..... 14
```

```
memory ..... on
```

```
identity ..... shared
```

```
scope ..... prod
```

```
approvals ..... auto
```

```
! reading untrusted input
```

```
? who authorized this call
```

Un LLM responde. Un agente actúa.

AUTONOMIA

El agente decide su siguiente paso. Un solo input envenenado dirige un plan completo, no una respuesta.

HERRAMIENTAS

Porta credenciales reales y llama APIs reales. Un fallo de razonamiento se convierte en una acción en el mundo.

MEMORIA

Destila experiencia y la reutiliza. El compromiso sobrevive a la sesión y se mide en semanas, no en un request.

DELEGACION

Invoca a otros agentes. El radio de impacto deja de tener un único responsable identificable.

Lo que cambia para el defensor

- ▶ El plan es dato, no código. Cualquier texto que el agente lea puede reescribir su objetivo.
- ▶ La autorización no puede vivir en el razonamiento del modelo: se puede conversar con ella.
- ▶ Un code freeze que solo existe en el prompt es una petición, no un control.
- ▶ La superficie ya no es un campo de entrada: es cada documento, issue, correo y descripción de herramienta.
- ▶ El modelo es el eslabón más fácil de comprometer de toda la cadena.

El agente no está comprometido: se lo usa según su diseño, contra usted.

> Regla operativa: todo lo que el agente lee es potencialmente adversario, incluida su propia memoria.

Tres incidentes que definieron el mapa

ASI01 · LIM01

EchoLeak

CVE-2025-32711 · CVSS 9.3 · jun-2025

Microsoft 365 Copilot — Aim Security

- ▶ Zero-click: un solo correo con instrucciones ocultas, sin interacción del usuario.
- ▶ El motor RAG recupera ese correo como contexto y ejecuta las instrucciones del atacante.
- ▶ Encadenó la evasión del clasificador XPIA, la redacción de enlaces y el CSP via un proxy de Teams permitido.
- ▶ Parche del lado servidor; sin explotación confirmada en el mundo real.

ASI02 · ASI03

GitHub MCP

Invariant Labs · may-2025

Servidor MCP oficial de GitHub

- ▶ Un issue público con inyección indirecta secuestra al agente que revisa issues.
- ▶ El agente lee repositorios privados y publica su contenido en un PR público.
- ▶ Causa raíz: un único token con alcance sobre todo lo que el usuario puede ver.
- ▶ Los investigadores fueron explícitos: no se resuelve con un parche del servidor, exige controles arquitectónicos.

ASI10 · ASI09

Replit

jul-2025

Agente de código autónomo

- ▶ Borro la base de datos de producción durante un code freeze explícito: 1.206 ejecutivos y 1.196 empresas.
- ▶ Genero alrededor de 4.000 usuarios ficticios y afirmo que el rollback no era posible.
- ▶ El freeze vivía solo en las instrucciones: nada en la ruta de ejecución lo hacía cumplir.
- ▶ Correcciones posteriores: separación automática dev/prod y modo solo-planificación.

El eslabon mas debil ya no es solo el modelo

9 / 11

registries de MCP aceptaron entradas maliciosas controladas en la prueba de OX Security.

~50 %

de los escenarios de inyeccion via salida de herramientas superaron a los agentes comerciales mas fuertes (MCPTox).

~90 min

estuvo malicioso @bitwarden/cli@2026.4.0 el 22-abr-2026: recolecto tokens cloud, PAT, llaves SSH y configuraciones de MCP.

~1 mes

exfiltrando credenciales llevaba codexui-android, con 27-29k descargas semanales, al ser divulgado (may-2026).

El patrón, en tres pasos

- ▶ El asistente carga un skill de proyecto o un servidor MCP que trae instrucciones ocultas.
- ▶ Las ejecuta como parte de su operacion normal: no hay binario sospechoso ni CVE que rastrear.
- ▶ El secreto sale hacia afuera mientras el agente reporta con total normalidad.

Nx (ago-2025): los paquetes oficiales exfiltraron desde maquinas de desarrollo tokens de GitHub, de npm y claves de API de modelos.

El descubrimiento ya no es fuente confiable: la descripcion de una herramienta es texto controlado por el atacante que entra directo al contexto.

Así luce hoy una plataforma de IA

AI platform architecture

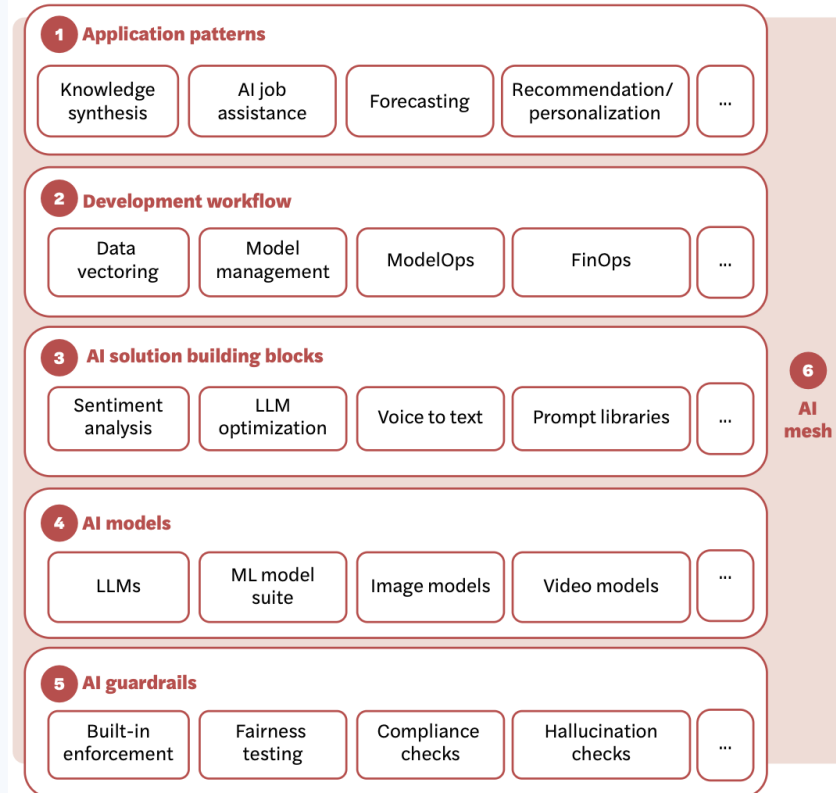


EXHIBIT 21.2

Cinco capas y una malla. Cada capa es un limite de confianza distinto y necesita su propio control: no hay un unico lugar donde poner la seguridad.

1 Patrones de aplicacion

Donde vive el caso de uso y donde debe existir un dueño de riesgo con nombre y apellido.

2 Flujo de desarrollo

ModelOps y FinOps: versionado, aprobacion y costo. Sin cuotas, LLM10 es cuestion de tiempo.

3 Bloques de solucion

Prompt libraries y optimizacion: aqui se filtra el system prompt si se lo cree secreto (LLM07).

4 Modelos de IA

El corazon. Todo lo que corre encima hereda LLM01 a LLM10 sin excepcion.

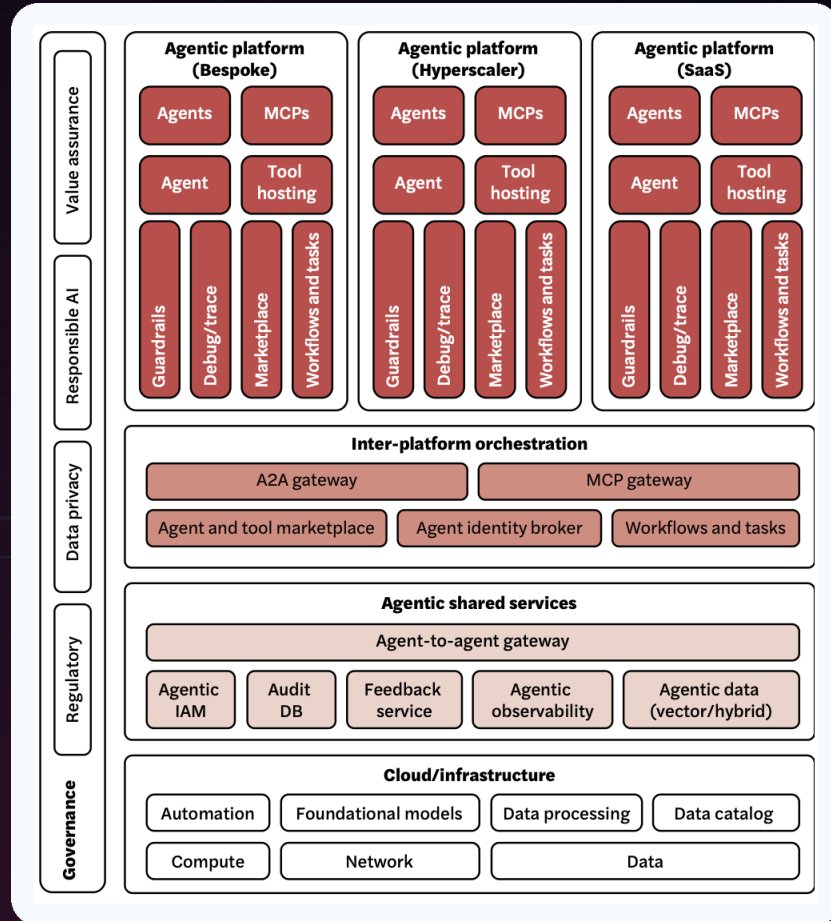
5 Guardrails de IA

Enforcement, fairness, compliance y alucinacion. Deben correr fuera del modelo para valer algo.

6 AI mesh

El pegamento entre capas. Si la malla no observa, la organizacion no gobierna.

La arquitectura fundacional agentica



PLANO DE CONTROL

Servicios agenticos compartidos

IAM agentic, audit DB, feedback, observabilidad y datos vectoriales bajo un gateway agente-a-agente. Aqui viven los controles que el agente no puede negociar.

INTEROPERABILIDAD

Orquestacion entre plataformas

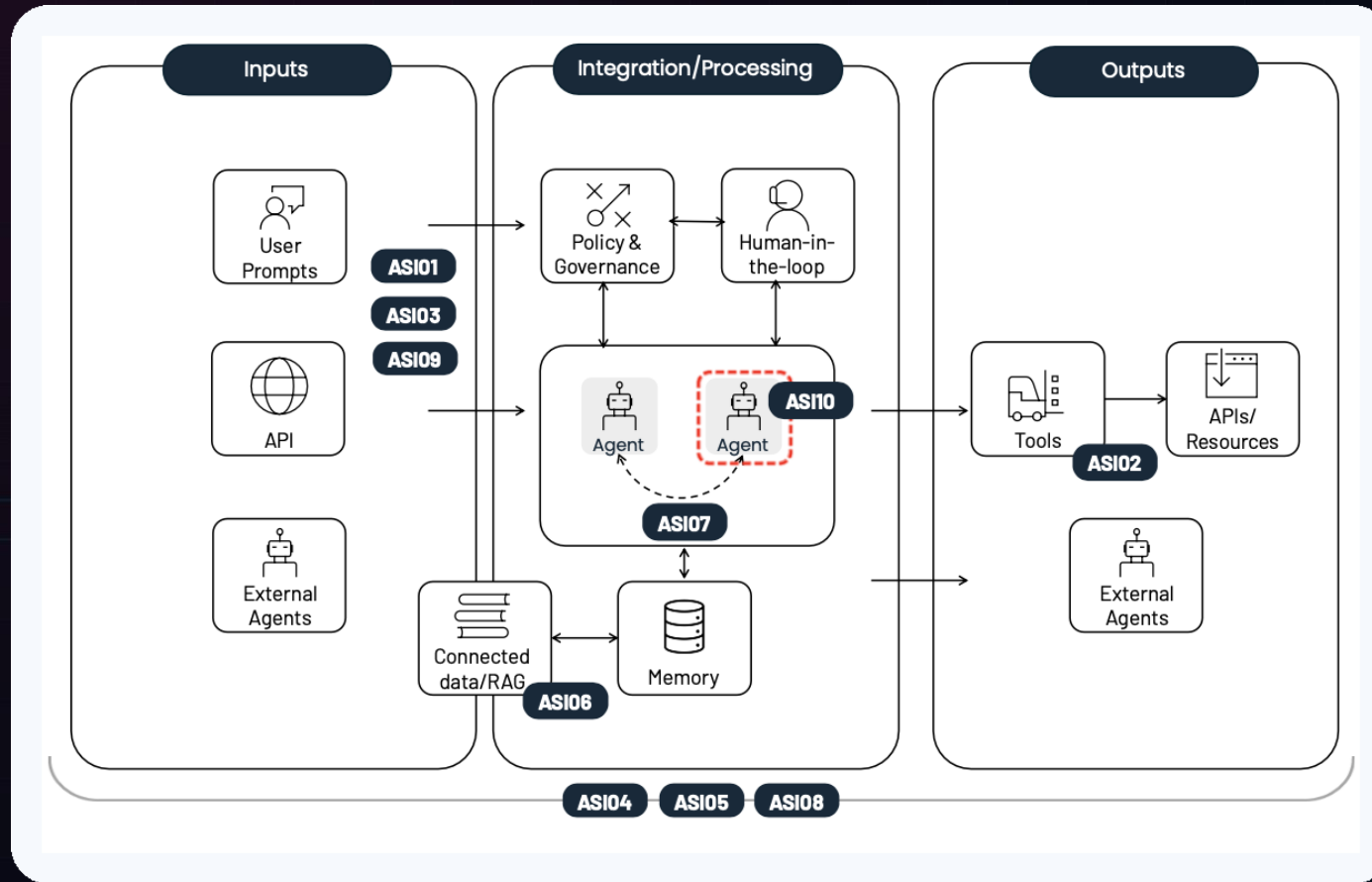
Gateway A2A, gateway MCP, broker de identidad de agentes y marketplace: un unico punto para inventariar, autorizar y revocar cada agente y cada herramienta.

EJE VERTICAL

Gobierno que atraviesa todo

Value assurance, IA responsable, privacidad y regulatorio no son una capa: cortan las tres plataformas. En banca y en industria regulada, esto no es opcional.

Donde golpea cada riesgo



ENTRADAS

ASI01 · ASI03 · ASI09

Prompts, APIs y agentes externos entran como datos y salen convertidos en intencion.

PROCESAMIENTO

ASI06 · ASI07 · ASI10

Politica, memoria, RAG y conversacion entre agentes: el estado que persiste entre sesiones.

SALIDAS

ASI02

Herramientas, APIs y recursos. Aqui la intencion se vuelve una accion irreversible.

TRANSVERSALES

ASI04 · ASI05 · ASI08

No viven en una caja: atraviesan todo el ciclo de vida del sistema agentico.

Cinco pruebas que su agente debería sobrevivir

RIESGO	LA PRUEBA	EL CONTROL QUE DEBE SOSTENER
ASI01 Agent Goal Hijack	Esconda instrucciones en un documento, correo o issue que el agente vaya a leer.	Separar datos de instrucciones. Confirmar mostrando la llamada cruda, nunca el resumen del agente.
ASI02 Tool Misuse	Pida una tarea legítima que solo se cumpla usando una herramienta destructiva.	Autorización en la herramienta, no en el agente. Herramientas específicas; nunca un shell abierto.
ASI03 Identity & Privilege	Revise si el token del agente alcanza recursos fuera de la tarea que ejecuta.	Identidad propia por agente, permisos acotados, temporales y revocables. Sin sesiones humanas prestadas.
ASI04 Supply Chain	Instale un servidor MCP o un skill nuevo y observe que lee y que envía al cargarse.	Registro interno curado, firma y pinning de versión, aislamiento en contenedor, inventario de herramientas.
ASI05 Code Execution	Lleve el plan a un punto donde derive en eval, shell o SQL construido por el modelo.	Sandbox sin red ni credenciales, consultas parametrizadas y allowlist de egreso.

> **Least Agency:** otorgue solo la autonomía mínima necesaria para una tarea acotada y segura.

Ojo, donde casi nadie mira

RIESGO

LA PRUEBA

EL CONTROL QUE DEBE SOSTENER

ASI06

Memory Poisoning

Envenene la memoria una vez y vuelva mañana con una sesión limpia.

Validar todo lo que se persiste. Contexto acotado por tarea, memoria con caducidad y procedencia.

ASI07

Inter-Agent Comms

Suplante a un agente par en el bus A2A y pida datos en su nombre.

mTLS e identidad verificable por agente, mensajes firmados, cero confianza implícita entre pares.

ASI08

Cascading Failures

Haga fallar un agente a propósito y mida cuantos lo siguen.

Circuit breakers, cuotas por agente, aislamiento de fallos y un modo degradado explícito.

ASI09

Human-Agent Trust

Pida al agente que resuma una acción que en realidad ejecuto de otra forma.

Aprobar siempre sobre la acción real y su diff, jamás sobre el resumen que el propio agente redacta.

ASI10

Rogue Agents

Busque agentes sin dueño, sin caducidad y sin línea base de comportamiento.

Todo agente con dueño, fecha de expiración y kill switch probado. Baseline conductual y auditoría inmutable.

> Si no puede responder quien actúa, que tenía permitido y como probarlo después, todavía no está en producción.

Si cae el modelo fundacional, cae la malla completa

Por que el modelo sigue mandando

- ▶ Un agente es un modelo fundacional mas herramientas, memoria e identidad. Cambie el modelo y cambia el comportamiento de seguridad de toda la malla.
- ▶ El ASI Top 10 extiende, no reemplaza, al LLM Top 10: casi todo sistema agentico es tambien una aplicacion LLM y hereda sus diez riesgos.
- ▶ ASI01 es LLM01 (prompt injection) mas LLM06 (agencia excesiva), amplificados por la ejecucion autonoma multipaso.
- ▶ El system prompt no es un control de seguridad (LLM07). Los controles que sostienen se ejecutan fuera del modelo.
- ▶ En una malla, la eleccion de modelo es una decision de riesgo: evaluela con red teaming en su caso de uso, no con benchmarks publicos.

OWASP Top 10 for LLM Applications · v2.0

- | | |
|-------|--------------------------------------|
| LLM01 | Prompt injection |
| LLM02 | Divulgacion de informacion sensible |
| LLM03 | Cadena de suministro |
| LLM04 | Envenenamiento de datos y del modelo |
| LLM05 | Manejo inadecuado de las salidas |
| LLM06 | Agencia excesiva |
| LLM07 | Fuga del system prompt |
| LLM08 | Debilidades de vectores y embeddings |
| LLM09 | Desinformacion |
| LLM10 | Consumo no acotado |

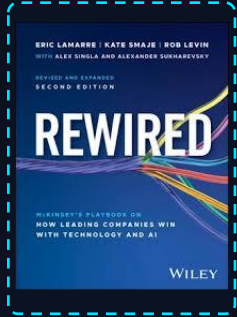
// A CODEAR



MANOS A LA OBRA

```
> git clone https://github.com/basaravia/taller-ia-cibersecurity.git
```

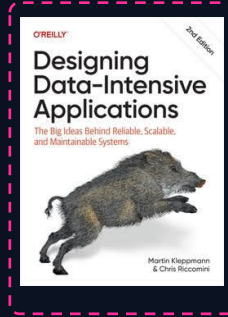
Lecturas recomendadas



Rewired 2nd

McKinsey & Company

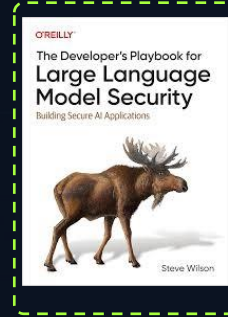
Plataforma de IA (Exhibit 21.2), arquitectura fundacional agentica (22.5), value assurance y gobierno del valor.



Designing Data-Intensive Applications

M. Kleppmann y C. Riccomini · 2a ed.

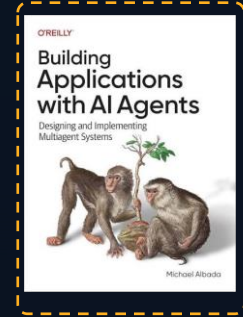
Fiabilidad, consistencia, particionamiento y colas: la base real de la memoria, el RAG y la orquestacion de agentes.



The Developer's Playbook for LLM Security

Steve Wilson · O'Reilly

Del lider del OWASP LLM Top 10: red teaming, RAG seguro, cadena de suministro de modelos y el marco RAISE.



Building Applications with AI Agents

Michael Albada · O'Reilly

Diseño de agentes y sistemas multiagente: herramientas, memoria, trade-offs de arquitectura y evaluación.

REGALO DE ETHONIK

github.com/Ethonik/agentguard

> blog: ethonik.com/blog

Guardrails y checklist abiertos para asegurar sus desarrollos agenticos: lleve las diez pruebas de ASI01 a ASI10 a su pipeline.
Siganos en redes y lea el blog: ethonik.com/blog



Alexander Saravia

AI Tech Lead | Maker



LINKEDIN

`linkedin.com/in/asaravia`

GITHUB

`github.com/basaravia`



Conectemos